LABORATUVAR 5 · MİRKA SMART WOODSANDER 5000 · Ahşap Zımpara Makinesi

SBOM / CVE / Patch

Çıktı: Vulnerability Decision

Ad Soyad: _____ Grup: _____ Tarih: ___/___/2026

Kavram: SBOM = yazılım malzeme listesi · CVE = açığın kayıt no'su · CVSS = ciddiyet (0–10). Bir CVE sizi etkiler mi? Üç şart: bileşen **var**, sürüm **etkileniyor**, açık **ulaşılabilir**.

Verilen zafiyet kaydı

Bileşen	WoodSander Component X (PLC firmware kütüphanesi)
Sürüm	2.4
CVE	CVE-XXXX-XXXX
Önem	Critical (CVSS 9.8)
Yama	Mevcut

Görev — karar akışı

1 Bu CVE sizi gerçekten etkiliyor mu? (üç şartı kontrol edin)

- **Bileşen var mı?** SBOM'da Component X kayıtlı mı → makinenin Üretim PLC firmware'inde var (kayıt doğrulanır).
- **Sürüm etkileniyor mu?** CVE'nin etkilenen aralığı ile kurulu sürüm (2.4) karşılaştırılır; 2.4 aralıktaysa evet.
- **Ulaşılabilir mi?** Açığa hangi arayüz/porttan gidiliyor? İnternete açık uzak bakım modülü bu yolu sağlıyorsa **ulaşılabilir** → risk yüksek. Üçü de evet ise **etkileniyoruz**; biri hayırsa öncelik düşer (ama kayıt tutulur).

2 Üretimi hemen durdurur musunuz? Neden / neden değil?

Hayır, otomatik durdurma yok — ama bekleme de yok. Önce **telafi edici önlem** (uzak erişimi kapat/VPN+MFA'ya al) hemen uygulanır; sömürü kanıtı varsa (loglarda şüpheli erişim) veya Safety etkileniyorsa üretim durdurulur. Aksi halde yama planlı bakım penceresine alınır. Sebep: CVSS tek başına karar değil; ulaşılabilirlik + emniyete etki belirleyicidir.

3 Yamayı doğrudan mı uygularsınız, önce test mi? Nerede test?

Önce test. Üretim makinesine doğrudan değil: **test tezgâhı / yedek PLC veya sanal ortamda** (aynı firmware + aynı konfigürasyonla) denenir; kabul sonrası planlı bakım penceresinde **yedek alınarak**, geri dönüş planıyla uygulanır. Zımpara kafası sürücü/hız senkronizasyonu ve haberleşme davranışı testin parçasıdır.

4 Bu yama bir safety validation etkiliyor mu? Nasıl anlarsınız?

- Üretici **sürüm notlarında** safety-related kod/kütüphane değişikliği var mı? Component X, **Safety PLC'nin sertifikalı yazılımına** dokunuyor mu?
- Etki ediyorsa: yama sonrası **safety fonksiyonlarının yeniden testi** (kapak kilidi, ışık perdesi tepki süresi, durma süresi, STO) ve Safety konfigürasyonunun CRC/imzasının doğrulanması şart.
- Emin değilsek varsayılan: **etkiliyor kabul et**, fonksiyon testi yap ve sonucu kayda al.

5 Yama mümkün değilse compensating control (telafi edici önlem) ne olur?

- Uzak erişimi kapat; yalnız VPN+MFA+jump server ve bakım penceresinde aç. • Firewall ile bileşenin portlarına erişimi kısıtla/segmentle.
- Safety zincirini ağdan izole tut (yazma yok). • Ek izleme: bileşene gelen anormal trafik ve konfigürasyon değişikliği alarmı.
- Geçici olarak ilgili servisi/portu devre dışı bırak; yama için tedarikçiyle tarih belirle ve riski Risk Register'da **kabul + süre sınırlı** kaydet.

Bu föyün çıktısı **Vulnerability Decision** → Evidence Pack **EP 09 · 10 · 11** başlığına oturur.